

CISSP Printable Practice Exam 10 - Domain 2 - Asset Security

Practice Exam 02 - Domain 2

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP2-025)

Scenario: An insurance group acquires a smaller firm whose three-level information classification scheme does not correspond directly to the group's four-level scheme. A migration team proposes converting labels solely by matching their names.

What should the security manager recommend FIRST?

- A. Develop a mapping based on the impact criteria and handling requirements behind each classification level.
- B. Adopt the acquired firm's labels for all migrated information until the next annual review.
- C. Map labels with similar names and resolve exceptions only when users report access problems.
- D. Assign the group's highest classification to every migrated asset to avoid underclassification.

Question 2 (CISSP2-026)

Scenario: A retail chain's data steward discovers that regional offices apply different labels to the same category of loyalty-program records. The steward maintains the business glossary and coordinates data-quality rules, but a marketing executive is the designated data owner.

Which action is MOST appropriate for the data steward?

- A. Unilaterally choose a new classification because the steward maintains the data definitions.
- B. Ask the storage administrator to select the label that is easiest to implement consistently.
- C. Document the inconsistency and coordinate a classification decision by the designated data owner.
- D. Leave the regional labels unchanged because classification must be determined locally.

Question 3 (CISSP2-027)

Scenario: A pharmaceutical company classified a market forecast as confidential before a product announcement. The announcement is now public, but the forecast also contains nonpublic supplier pricing and production-capacity data. A communications manager requests immediate declassification of the entire document.

How should the security manager handle this request?

- A. Declassify the document because its original embargo has ended.
- B. Have the data owner reassess all remaining content and approve any downgrade under the classification policy.
- C. Let the communications manager remove the label because that manager controls publication.
- D. Keep the original classification permanently because classifications cannot be lowered after creation.

Question 4 (CISSP2-028)

Scenario: A legal services firm prints restricted case summaries for use in a temporary

project room. Electronic copies are tightly controlled, but printed copies are left on tables overnight and no one records how many were produced.

Which measure would BEST align the printed summaries with their classification?

- A. Permit unattended copies because the project room requires a badge for entry.
- B. Replace the restricted label with an internal-use label on printed versions.
- C. Ask each user to remember which pages were printed and report losses voluntarily.
- D. Control copy issuance, use approved locked storage, and reconcile copies for return or secure disposal.

Question 5 (CISSP2-029)

Scenario: A municipal transit authority is cataloging the systems and information that support train dispatch. Technical teams can describe system dependencies, but the authority needs an accountable role to determine how service disruption affects the transit mission and to set recovery priorities.

Which role should own this determination?

- A. The system administrator who maintains the dispatch servers
- B. The data custodian who operates backup and storage services
- C. The business or mission owner accountable for the supported transit function
- D. The data processor that performs scheduled operations on dispatch records

Question 6 (CISSP2-030)

Scenario: An architecture firm engages contractors for a six-week project. Project managers currently request broad application access and laptops without identifying an end date, asset custodian, or return obligation.

Which provisioning change would MOST effectively reduce lifecycle risk?

- A. Issue standard employee access so contractors can assist with unexpected work.
- B. Require sponsor-approved role access, assigned-asset records, expiration dates, and documented return steps.
- C. Permit project managers to retain spare laptops between contractor engagements.
- D. Perform a manual access and equipment review at the end of each fiscal year.

Question 7 (CISSP2-031)

Scenario: A hospitality company allows support staff to keep installation packages in shared folders. Several packages have unknown origins, duplicate version names, and no documented approval, although some may still be needed for supported systems.

What should the asset manager do FIRST?

- A. Establish an authoritative repository containing verified, approved, version-controlled software packages.
- B. Keep every package because deleting an older version might affect a future recovery.
- C. Allow support staff to rename packages so the versions appear consistent.
- D. Move all packages to a less visible folder without changing approval or provenance records.

Question 8 (CISSP2-032)

Scenario: A nonprofit organization is closing a regional office. The site contains active laptops, retained paper records, leased equipment, and unused storage media assigned to several departments. The closure team wants to move everything to a warehouse without review.

Which TWO actions should be completed before the move? Select 2 of the 5 options below.

- A. Reconcile each asset with the inventory, accountable owner or custodian, and current disposition status.
- B. Apply approved retention and disposition requirements to determine what must be transferred, returned, or retired.
- C. Remove asset labels so receiving staff can create a new inventory without inherited assumptions.
- D. Retain all materials until warehouse capacity becomes constrained.
- E. Let individual movers decide which items appear obsolete enough to discard.

Question 9 (CISSP2-033)

Scenario: A tax-preparation service deletes expired client records from production systems according to policy, but the same records remain recoverable from backups for many additional years. No recovery requirement, regulatory obligation, or active hold supports the extended period.

Which response BEST addresses the inconsistency?

- A. Exclude backups from the retention policy because their primary purpose is system recovery.
- B. Stop creating backups of any system that contains records with expiration dates.
- C. Permit extended backup retention because restoring old data requires management approval.
- D. Revise backup schedules and disposal procedures so recoverable copies follow approved retention and recovery needs.

Question 10 (CISSP2-034)

Scenario: A regional airline stores hundreds of aging laptops as emergency spares. Many are unsupported, no longer assigned, and absent from routine maintenance, but departments resist disposal because the devices might someday be useful.

What is the MOST appropriate course of action?

- A. Retain all devices because potential future use is a sufficient business justification.
- B. Evaluate documented spare-capacity needs, reconcile the inventory, and retire unsupported excess through approved disposition.
- C. Distribute the unsupported devices to employees so the storage area can be cleared quickly.
- D. Remove the devices from inventory while keeping them available for emergency use.

Question 11 (CISSP2-035)

Scenario: A sports venue is designing a visitor application for digital tickets. The proposed registration form collects birth dates, household income, precise location history, and government identifiers, although ticket delivery requires only contact and payment information.

Which design decision BEST reduces asset-security risk at the start of the data lifecycle?

- A. Collect only data necessary for the defined ticketing purpose and document any justified additional fields.
- B. Collect every proposed field but archive the unused values immediately after registration.
- C. Collect the data now because future marketing uses may eventually justify retention.

D. Let each application developer decide which fields appear sensitive enough to omit.

Question 12 (CISSP2-036)

Scenario: A land-management agency must retain survey records for several decades. A review finds that some archived files use obsolete formats, restoration tests are not performed, and broad administrator groups can browse the archive.

What should the records owner prioritize?

- A. Move the archive to faster storage while preserving all existing permissions and formats.
- B. Print every record and treat the paper copies as the sole authoritative archive.
- C. Maintain readable formats, test retrieval and integrity, restrict access, and preserve scheduled disposition metadata.
- D. Disable all access until the end of the retention period to prevent unauthorized browsing.

Question 13 (CISSP2-037)

Scenario: A technology cooperative is sanitizing functioning storage media. Some devices will be reassigned internally after holding routine internal data; others held sensitive data and will be donated outside the organization. Approved purge methods are supported and verifiable on the donation media.

Which TWO sanitization decisions are most appropriate? Select 2 of the 5 options below.

- A. Clear the internally reassigned media using an approved method appropriate to its data and reuse context.
- B. Purge the donation media using a supported, approved, and verified technique before release.
- C. Clear the donation media by deleting file-system references because the devices still function.
- D. Destroy the internally reassigned media because reuse within the same organization is prohibited.
- E. Skip sanitization when the receiving party signs an agreement limiting data recovery.

Question 14 (CISSP2-038)

Scenario: A payment-processing organization has strong safeguards for stored records, but its handling standard does not address exports between approved systems or sensitive values displayed during authorized processing. The data owner wants consistent protection throughout the lifecycle.

Which approach BEST meets the data owner's objective?

- A. Treat stored-data controls as sufficient because exports and processing are temporary states.
- B. Prohibit all data movement and on-screen use, regardless of the approved business process.
- C. Delegate control selection to each system administrator without a common handling standard.
- D. Define classification-based requirements for data at rest, in transit, and in use, then tailor implementation to each environment.

Question 15 (CISSP2-039)

Scenario: A customer-support center needs account records to resolve billing issues. Agents must recognize the correct customer and transaction, but they do not need to see complete

payment identifiers or full government-issued identifiers during routine calls.

Which control is MOST appropriate for this use case?

- A. Display complete values and rely on annual confidentiality training.
- B. Mask unnecessary portions of sensitive fields while exposing only the values required for the task.
- C. Archive the records before each support interaction and restore them when requested.
- D. Provide unrestricted exports so agents can work without application constraints.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP2-025) - Correct: A

A defensible mapping compares the sensitivity, criticality, business impact, and required handling represented by each level; names alone may conceal material differences. Retaining the old labels delays integration, name matching may misclassify assets, and assigning the highest level to everything creates unnecessary cost and usability constraints.

Question 2 (CISSP2-026) - Correct: C

The steward should identify and coordinate resolution of the governance inconsistency, while the data owner retains accountability for approving classification and use requirements. Maintaining definitions does not grant unilateral classification authority. A storage administrator implements controls, and leaving inconsistent labels in place undermines uniform handling.

Question 3 (CISSP2-027) - Correct: B

The end of one sensitivity condition does not eliminate other confidential content. The accountable owner should reassess the entire asset and authorize any downgrade through the established process. Publication authority does not replace ownership accountability, while permanent classification ignores legitimate lifecycle changes and creates overprotection.

Question 4 (CISSP2-028) - Correct: D

Classification follows the information across formats, so printed copies require accountable issuance, protected storage, and controlled return or disposal. Room access alone does not establish custody of each copy. Changing a label because of format is unjustified, and informal recollection cannot provide reliable accountability.

Question 5 (CISSP2-029) - Correct: C

The business or mission owner is accountable for defining the importance of the supported function, evaluating operational impact, and setting business priorities. Administrators and custodians provide technical information and implement controls, while a processor performs defined data operations; none owns the transit mission itself.

Question 6 (CISSP2-030) - Correct: B

Time-limited provisioning should link approved need, least-privilege access, accountable asset assignment, automatic expiration, and return procedures. Standard employee access exceeds the stated need, retained spare assets weaken custody, and an annual review leaves temporary access and equipment unmanaged long after the engagement ends.

Question 7 (CISSP2-031) - Correct: A

An authoritative repository brings software provisioning under lifecycle control by establishing provenance, integrity, approval, and version status. Indefinite retention preserves unknown and potentially unsafe packages. Renaming does not verify content, and relocating the files does not correct the missing governance information.

Question 8 (CISSP2-032) - Correct: A, B

Inventory reconciliation preserves custody and accountability, while approved retention and disposition rules determine the proper treatment of each asset category. Removing labels breaks traceability. Capacity-driven retention ignores legal and business requirements, and disposal decisions by movers bypass accountable owners and controlled processes.

Question 9 (CISSP2-033) - Correct: D

Retention governance must account for recoverable copies, including backups, while still

supporting defined recovery needs and holds. Excluding backups leaves expired information exposed, eliminating backups harms resilience, and access approval does not remove the risk or justify retaining data beyond a validated requirement.

Question 10 (CISSP2-034) - Correct: B

A controlled retirement decision should be based on validated operational need, accurate inventory, supportability, and approved disposition. Speculative usefulness does not justify indefinite retention. Distribution expands exposure, while removing retained devices from inventory destroys accountability without reducing risk.

Question 11 (CISSP2-035) - Correct: A

Data minimization reduces exposure by preventing unnecessary sensitive information from becoming an organizational asset in the first place. Immediate archiving still creates and retains the data, speculative future use lacks a defined need, and individual developer judgment cannot replace documented business and governance decisions.

Question 12 (CISSP2-036) - Correct: C

Archival controls must preserve confidentiality, integrity, availability, readability, and eventual disposition for the entire retention period. Faster storage does not correct obsolete formats or excessive access. Paper-only conversion may reduce usability and resilience, while disabling all access defeats legitimate retrieval requirements.

Question 13 (CISSP2-037) - Correct: A, B

Clearing can be appropriate for controlled internal reuse when it meets the risk and policy requirements. Sensitive media leaving organizational control should receive the stronger assurance of a supported, verified purge when reuse is intended. Simple deletion is insufficient, destruction is not automatically required for internal reuse, and contractual language does not remove data remanence.

Question 14 (CISSP2-038) - Correct: D

Protection requirements should follow the data through storage, transfer, and active use, with implementations tailored to the environment while preserving the classification objective. Temporary states still create exposure. A blanket prohibition may prevent legitimate operations, and decentralized choices without common requirements produce inconsistent protection.

Question 15 (CISSP2-039) - Correct: B

Data masking limits exposure of sensitive values during authorized use while preserving the information agents need. Training is valuable but does not minimize displayed data. Repeated archiving does not solve the in-use requirement, and unrestricted exports increase both disclosure and uncontrolled-copy risk.